

1. Notre démarche

Pour analyser la demande de Victor, nous avons suivi la méthode du « Privacy by Design » vue en cours. Nous avons d'abord regardé quelles données personnelles étaient traitées, puis nous avons comparé le projet aux grands principes du RGPD.

On a vite écarté l'intérêt légitime : avec le cours précédent ou l'on a vu l'exemple avec Amazon, une surveillance systématique et invisible ne passe plus. Nous avons donc considéré ce point comme un manquement majeur au RGPD.

2. Grille d'analyse de conformité

Obligations du RGPD à contrôler	Questions à se poser	Réponses concernant la conformité	Solution / Mesure correctrice
Principe de Finalité	Les données sont-elles utilisées pour un but déterminé et légitime ?	NON CONFORME. Les badges sont collectés pour la « sécurité des biens et des personnes ». Les utiliser pour le contrôle horaire est un détournement de la finalité prévu à la base.	Victor doit avoir un but qui est clair. Il ne peut pas « recycler » les données de sécurité sans base légale.
Principe de Transparence	Les personnes sont-elles informées de l'usage de leurs données ?	NON CONFORME. Victor souhaite cacher le dispositif aux salariés et aux syndicats pour éviter "d'être embêté".	L'information est une obligation du RGPD. Il faut mettre à jour la Charte et informer tout le personnel.
Principe de Minimisation	Collecte-t-on uniquement les données strictement nécessaires ?	NON CONFORME. Demander la situation maritale, les chèques garde d'enfants ou les avances sur salaire est abuser pour contrôler des horaires.	Supprimer du modèle toutes les données qui n'ont pas de lien direct avec le temps de présence.

SAE : Conformité

Obligations du RGPD à contrôler	Questions à se poser	Réponses concernant la conformité	Solution / Mesure correctrice
Données Sensibles et Vie Privée	Le traitement révèle-t-il des informations hautement personnelles ?	NON CONFORME. Le profilage basé sur les congés « enfant malade » ou autre touche à la santé et à la vie privée.	Interdiction de profiler sur des motifs de congés. Utiliser uniquement des données de présence sans déduire la situation familiale.
Décision automatisée	Y a-t-il une intervention humaine avant une sanction ?	NON CONFORME. L'envoi automatique d'avertissements "emails de masse" avec impact sur la carrière est interdit par le RGPD.	Un être humain doit impérativement valider le problème avant un envoi d'email d'avertissement.
Principe de Sécurisation	Les données sont-elles protégées durant le transfert ?	NON CONFORME. Victor demande l'envoi d'un fichier Excel nominatif par email avec un titre explicite.	Le fichier doit être pseudonymisé pour éviter l'identification des salariés en cas d'attaque.
Profilage	Le profilage est-il encadré ?	NON CONFORME. Le profilage des « abuseurs » sur des critères d'âge ou de parentalité est discriminatoire et intrusif.	Annuler cette partie du projet. On peut repérer des anomalies de pointage, mais pas « profiler » les individus sur leur vie privée.

3. Ce qu'on en retient

Le projet de Victor présente beaucoup trop de risques juridiques pour l'entreprise. Si on doit le réaliser demain, on risque le même genre de scénario qu'Amazon avec des amendes pour "surveillance excessive".

- On ne peut pas surveiller les gens dans leur dos.
- Automatiser des sanctions sans vérification humaine est interdit.
- Le profilage basé sur l'âge ou la parentalité est une faute éthique et illégale.

Notre avis : Il faut mettre le projet en pause le temps de voir avec le DPO et être transparent avec les salariés et arrêter le profilage intrusif.